

NovaPay Zero-Downtime CI/CD

NovaPay

Zero-Downtime CI/CD

TRC Decision Package

20-slide maximum

Banking / Regulated

- Production-grade CI/CD for a regulated banking platform
- Decision requested: approve the target architecture, controls and phased rollout
- Assessment basis: Zero-Downtime CI/CD Pipeline Assessment | 20-slide maximum

1. Executive Decision

- Approve a four-environment GitOps delivery model: dev → staging → pre-prod → production.
- Approve an eight-stage DevSecOps pipeline with blocking security/compliance gates.
- Approve Istio-based blue-green traffic switching plus progressive canary verification.
- Approve expand–migrate–contract database migration with backward compatibility.
- Approve automated rollback for critical SLO breaches; production promotion remains dual-approved.
- Business outcome: move from manual, high-risk releases to auditable, repeatable and reversible change.

2. Current State — Why Change Is Required

- Manual SSH deployments; no CI/CD control plane and weak change traceability.
- 3 production incidents in Q4 2025 were traced to untested code deployments.
- Deployment frequency: once every 2 weeks.
- MTTR: 4.5 hours; assessment target: <15 minutes.
- 17 outstanding RBI audit non-conformances and no automated compliance scanning.
- Database changes performed manually in 2 AM maintenance windows.
- Zero observability: incidents are detected by customers rather than systems.
- Risk conclusion: velocity, availability, auditability and change safety are all constrained.

3. Target State & Success Measures

- Five-nines availability objective: 99.999%.
- Commit-to-production: <2 hours overall project target; pipeline lead-time target <1 hour.
- Deployment frequency: multiple production deployments/day.
- Change failure rate: <5%; assessment DORA scorecard target.
- Recovery: automated rollback in seconds for Category A; <15 min operational target.
- Security: critical findings block release; signed immutable artifacts only.
- Compliance: 6+ automated gates with thresholds, evidence and time-bound exceptions.
- Principle: same artifact across environments; configuration changes only.

4. Solution Architecture — End to End



- GitHub Enterprise → CI/CD → JFrog Artifactory → Argo CD → Kubernetes/EKS.
- Istio provides mTLS, weighted traffic routing and blue-green/canary control.
- Shared state: PostgreSQL 16 + pgBouncer, Redis 7 cluster, RabbitMQ 3.13.
- Observability: Prometheus/Grafana metrics, OpenTelemetry traces, Loki logs.
- Security controls: SonarQube, Trivy, OWASP ZAP, OPA/Kyverno, signed images.
- Terraform provisions cloud infrastructure; Helm packages the application.

5. Eight Canonical Pipeline Stages



- 1 Source & Trigger — protected branches, signed commits, PR review.
- 2 Build & Compile — reproducible build, unit tests, coverage $\geq 80\%$ line / $\geq 70\%$ branch.
- 3 SAST — SonarQube: 0 Critical, ≤ 2 High, technical debt $\leq 5\%$ for new code.
- 4 Dependency & Container — Trivy/Grype, SBOM, Critical CVE = block; CVSS ≥ 9 = block.
- 5 Integration & Contract — Pact, ephemeral namespaces, DB/API compatibility.
- 6 DAST — authenticated OWASP ZAP; 0 Critical/High from OWASP Top 10.
- 7 Policy & Compliance — OPA/Kyverno, image provenance, SoD, RBI/PCI checks.
- 8 Deploy & Verify — blue-green/canary, smoke/synthetic checks, automated rollback.

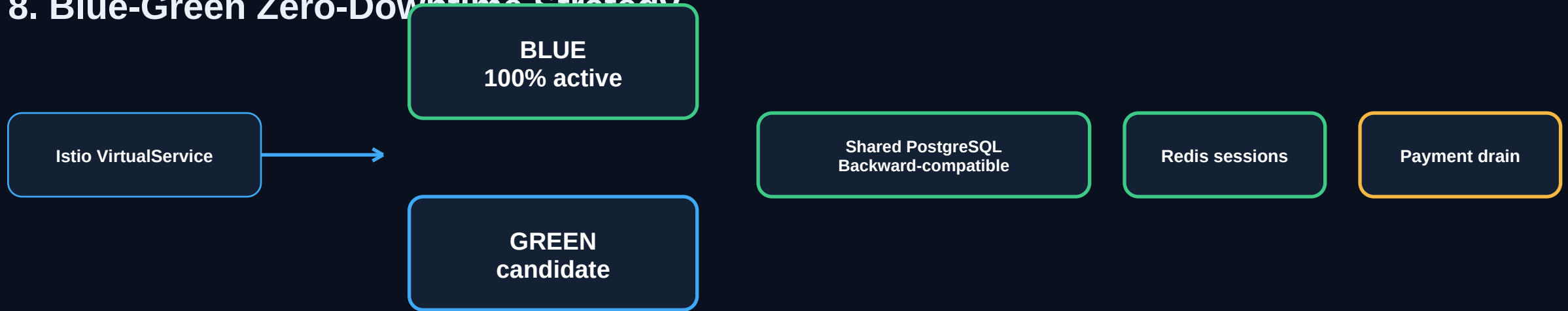
6. Artifact Supply Chain & Provenance

- Version every artifact with SemVer + Git SHA + build timestamp + CI run ID.
- Never use 'latest' in production.
- Build once; promote the same immutable image through all four environments.
- Sign container images with Cosign/Notary; admission policy rejects unsigned images.
- JFrog Artifactory is the controlled registry for container images and Helm charts.
- Evidence chain: commit → workflow run → scan results → signed artifact → Argo CD sync → cluster.

7. Environment Promotion & GitOps

- Dev: automatic after merge; synthetic/mock data; fast feedback.
- Staging: integration, DAST and performance testing; anonymized production-like data.
- Pre-prod: UAT, compliance and production-scale validation; manual approval.
- Production: real traffic; SRE + Release Manager dual approval; no mandatory gate bypass.
- Argo CD continuously compares Git desired state with cluster state and self-heals where enabled.
- Secrets are injected from Vault/AWS Secrets Manager; never stored in Git, Helm values or manifests.
- Feature flags support progressive enablement: 1% → 10% → 50% → 100%.

8. Blue-Green Zero-Downtime Strategy



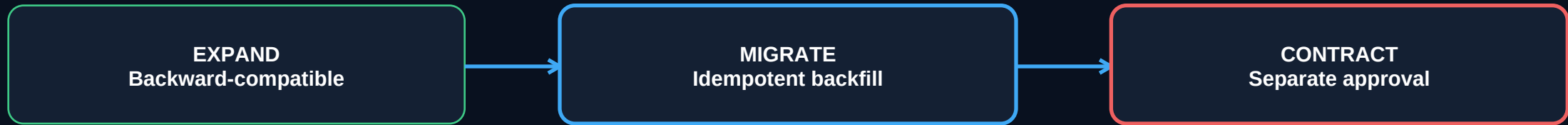
- Maintain two production-capable colors: Blue (active) and Green (candidate).
- Deploy and validate the candidate before switching traffic.
- Istio VirtualService changes traffic atomically between color subsets.
- Connection draining: stop new connections, finish in-flight requests, then terminate old pods.
- Payment jobs receive a configurable drain window (up to 5 minutes in the assessment model).
- Redis keeps sessions distributed across the switch; PostgreSQL is shared and must remain backward compatible.
- Rollback = route traffic back to the previous healthy color; old environment is retained until stable.

9. Canary Strategy & Statistical Promotion



- Use 95% confidence for automated promotion and a rolling 7-day production baseline.
- Any failed criterion pauses promotion and invokes rollback logic.

10. Zero-Downtime Database & Transaction Safety



- Abort migration automatically if query latency impact exceeds 20% (assessment threshold).
- pgBouncer protects connection management; pool exhaustion is a critical rollback signal.
- RabbitMQ supports asynchronous work; long-running payment jobs are drained before termination.
- Compatibility rule: both old and new application versions must safely operate during migration.

11. Compliance Gate Control Plane

SAST
0 C / ≤ 2 H / $\geq 80\%$

DAST
0 C/H

Dependency
0 Critical + SBOM

License
No GPL/AGPL/SSPL

Policy
100% pass

Infra
No privileged

- Every gate records threshold, result, evidence, remediation, exception approver and expiry.

12. RBI / PCI-DSS / Segregation of Duties Mapping

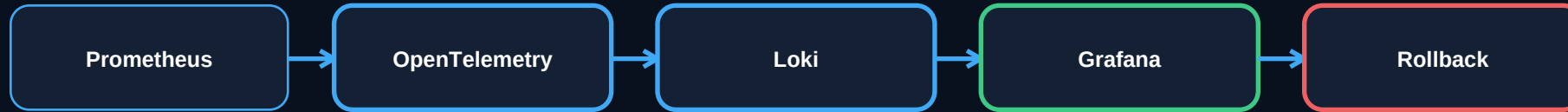
RBI
Change • SoD • Vulnerability • Audit

PCI DSS
6.2–6.5 • 10.2 • 11.3 • 12.6

SoD
Dev ≠ Deploy • RM + SRE

- RBI assessment mapping: change management → tested change + approvals + rollback.
- RBI assessment mapping: segregation of duties → separate development/deployment permissions.
- RBI assessment mapping: vulnerability management → SAST + DAST + dependency scanning.
- RBI assessment mapping: encryption → TLS/encryption policy gates.
- RBI assessment mapping: audit trail → immutable pipeline/change records.
- PCI-DSS assessment mapping: 6.2 software security; 6.3 vulnerabilities; 6.4 public-facing protection; 6.5 change management.
- PCI-DSS assessment mapping: 10.2 audit logging; 11.3 penetration testing; 12.6 awareness.
- Important: this is an assessment control mapping, not legal advice; final compliance interpretation belongs to Compliance/Legal.

13. Observability, SLOs & DORA



- Category A rollback: 5xx >5% for 60s, 3 consecutive health failures, OOM/CrashLoopBackOff, pool exhaustion.
- Category B escalation: p99 >2× baseline for 5 min, burn rate >10× for 10 min, transaction success –2%, CPU >90% or memory >85% for 5 min.
- Assessment DORA scorecard: deployment frequency, lead time, change failure rate, MTTR.
- Current DORA research has evolved to five delivery metrics; retain the assessment's four for scoring and add rework rate operationally.

14. Automated Rollback & Incident Response

T+0	12% 500s + DB pool + 35% gateway
T+30s	SEV-1 / freeze
T+1m	Stable traffic
T+2m	Escalate
T+5m	Verify
T+10–15m	Evidence / root cause

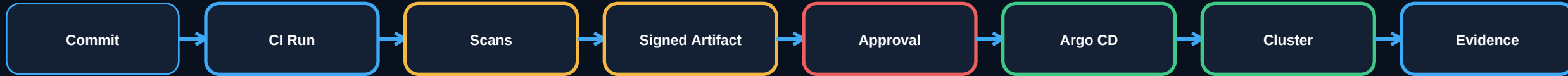
15. Friday 5:07 PM Incident — Decision Timeline

- T+0: 3 alerts fire during an 8-minute canary: HTTP 500 = 12%, DB pool exhaustion, payment gateway timeout = 35%.
- T+30s: classify as SEV-1/critical; freeze canary promotion and page on-call/SRE.
- T+1m: route traffic back to stable color; stop candidate exposure; protect payment processing.
- T+2m: notify CTO/CISO/VP Eng; open incident channel and status communication.
- T+5m: verify error rate, connection pool, payment success and synthetic transaction recovery.
- T+10–15m: preserve logs/traces/artifact/gate evidence; identify bypassed staging as the control failure.
- Preventive action: hotfix path must be expedited but cannot bypass security/compliance gates.

16. Risk Register & Mitigations

- R1 Release introduces payment regression → canary + synthetic transactions + automatic rollback.
- R2 Schema incompatibility → expand-contract + compatibility tests + pre-prod production-scale validation.
- R3 Session loss → shared Redis cluster + session health monitoring.
- R4 Supply-chain compromise → signed artifacts + immutable registry + admission policy.
- R5 Compliance bypass → blocking gates + SoD + time-bound exception workflow.
- R6 Observability blind spot → metrics/traces/logs + SLO alerting + dashboards.
- R7 Capacity shortage during blue-green → reserve headroom and verify cluster capacity before promotion.
- R8 Configuration drift → GitOps reconciliation + alerts + controlled manual changes.

17. Implementation Roadmap & Governance



- 0–15 days: architecture, pipeline stages, deployment strategy, gates, migration, promotion, rollback, runbook, observability and TRC package.
- Days 16–30: platform bootstrap — Terraform, managed Kubernetes, registry, Argo CD, Istio, observability.
- Days 31–60: application pipeline, security/compliance gates, artifact signing, Helm and promotion automation.
- Days 61–75: blue-green/canary, DB migration rehearsal, load testing, incident simulation.
- Days 76–90: production readiness, evidence collection, DR/rollback rehearsal, controlled production rollout.
- Governance: Release Manager + SRE Lead approve production; Compliance/Security own gate policy; Dev owns code quality; SRE owns runtime reliability.

18. Evidence, Auditability & TRC Approval

- Evidence package: pipeline runs, signed commits, SBOMs, scan reports, policy results, approvals, Argo CD sync history, deployment/rollback events and monitoring snapshots.
- Traceability objective: every production change is attributable to a person, commit, artifact, approval and deployment event.
- Operational deliverables: architecture, deployment strategies, compliance gates, DB migration, environment promotion, rollback specification, runbook/playbook and observability.
- Repository evidence includes IaC (Terraform), Helm templates, Argo CD Applications, policies, dashboards and test results.
- TRC decision requested: APPROVE architecture and controlled rollout, subject to environment-specific validation and formal compliance sign-off.

19. Q&A; — Defensible Answers for the TRC

TRC DECISION: APPROVE CONTROLLED ROLLOUT

- Why Istio? → Separates traffic policy from workload scaling and supports weighted version routing.
- Why same artifact? → Prevents environment drift and makes audit provenance deterministic.
- Can an emergency hotfix bypass gates? → It can be expedited, but security/compliance gates remain mandatory.
- How is zero downtime proven? → Readiness + synthetic transactions + SLO checks + connection/payment draining + traffic rollback.
- What if the DB change fails? → Expand/migrate phases are reversible/idempotent; contract is isolated behind its own approval gate.
- What proves compliance? → Machine-generated evidence tied to commit, artifact, policy result and approval.

20. Approval Request & References

- TRC approval requested for the target architecture and phased implementation.
- Assessment anchors: NovaPay scenario, 8-stage pipeline, blue-green/canary, expand-contract DB migration, 6+ compliance gates, DORA scorecard, incident simulation and 20-slide TRC requirement.
- Primary technical references: RBI Master Direction on IT Governance; PCI DSS v4.x; DORA software delivery metrics; Argo CD documentation; Istio traffic management.
- Note: regulatory mappings in this presentation reproduce the project's assessment framework and should be validated by NovaPay Compliance/Legal before real-world use.
- End state: Deploy Fast. Stay Compliant. Never Go Down.